



Figure 1: Execution summary



Figure 2: Detailed report

- To run the scan command, type the command `talisman --scanWithHTML`
- Running this command will create a folder named `talisman_html_reports` in the root of the current directory and store the report files there.

The above steps take us to the final point, which is manual analysis.

`talisman --scanWithHTML` creates pretty and easy-to-understand reports, which help the team to understand the errors caught by Talisman for the specific repository. Figures 1, 2, 3 and 4 show some sample reports that you can archive in your CI/CD environment.

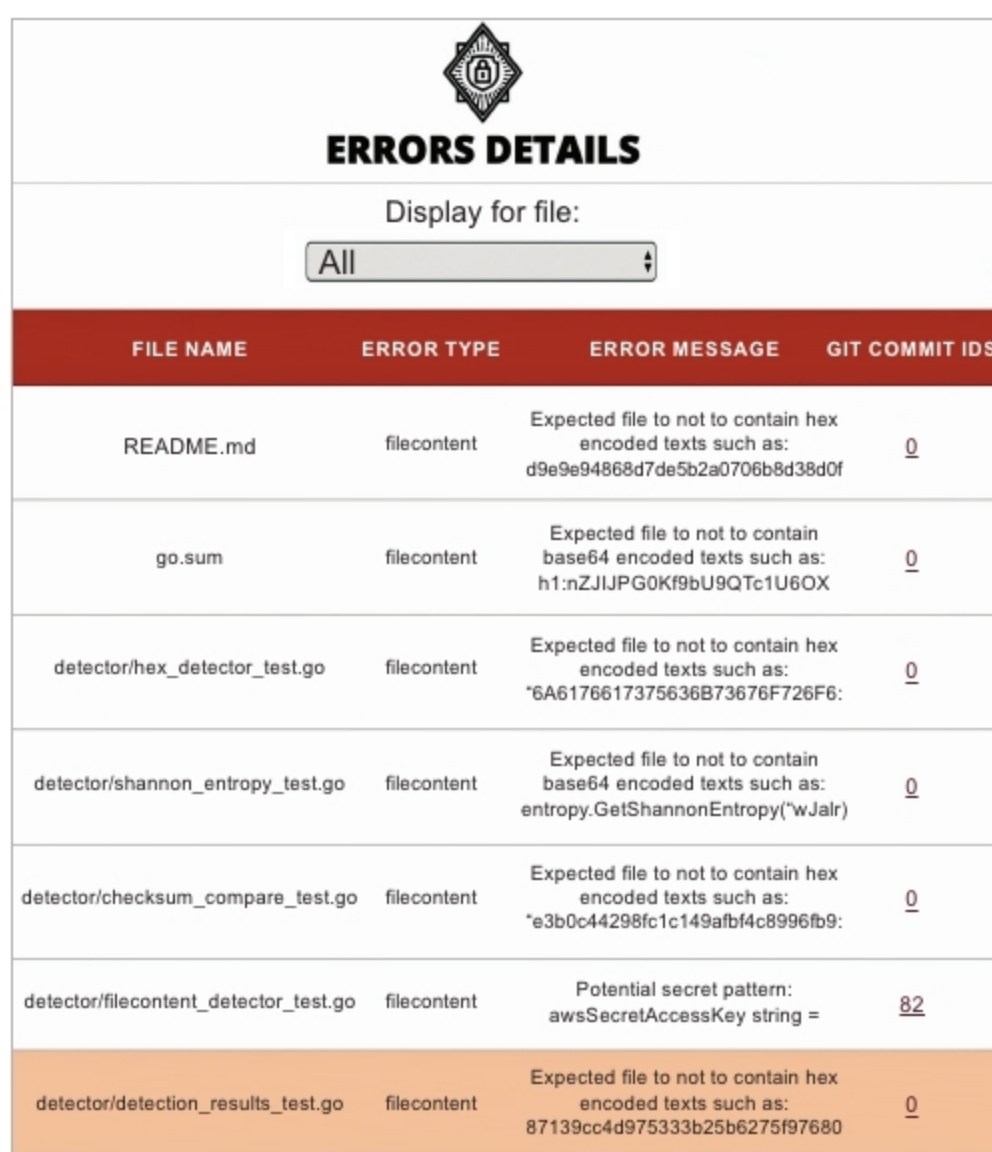


Figure 3: Specific error details

It is important to understand that securing your secrets is absolutely essential because sometimes the stakes are really

high. The consequences can destroy an organisation's or an individual's reputation in no time. Taking absolute care of our secrets is a practice that

we need to cultivate and use the tools to make our lives easier. By now the industry has probably started to understand the importance of pushing security towards the beginning of the development life cycle to mitigate the cost of finding bugs towards the end. Taking care of sensitive data is a part of this process as well, and a shift in mindset is needed to achieve the 'Shift left' in security as well. **END** 🐧

References

- [1] Talisman github README: <https://github.com/thoughtworks/talisman>
- [2] Talisman HTML report: <https://github.com/jaydeepc/talisman-html-report>
- [3] Bloomberg report on Uber breach: <https://www.bloomberg.com/news/articles/2017-11-21/uber-concealed-cyberattack-that-exposed-57-million-people-s-data>
- [4] CNBC report: <https://www.cnbc.com/2018/09/26/uber-to-pay-148-million-for-2016-data-breach-and-cover-up.html>

By: Jaydeep Chakrabarty

The author works at Thoughtworks Technologies, India. He has been contributing to the open source community for the last 14 years. Among the various open source projects (across tech-stacks) that he has contributed to are Talisman, OpenStack projects, Report-mine and Taiko.